



Figure 1: Virtualisation architecture—the basic blocks

and OS layers. The benefit in this method is that it takes a lower toll on system resources, resulting in faster guests—but it compromises on security. The third type is called OS-level virtualisation, in which the abstraction layer simulates multiple instances of the host OS. Hypervisor is the most famous type of installation.

Xen open source virtualisation

As we all know, the open source world has been blessed with Xen, which provides the great features of an industry-standard hypervisor technology. Xen allows us to create multiple guest instances and seamlessly schedules CPU time, and partitions memory spaces. The Xen architecture contains three main components: the hypervisor layer, the domain manager and the guest instances.

The Xen domain manager is a kernel component that runs before any other guest instance can be started. It provides functions such as allowing the creation of child domains, creating and managing virtual devices for guest domains, and also controlling network and disk resources. Guest instances are not allowed to access hardware resources directly—in fact, they communicate with the domain manager through proxy calls to ask for access. They also update the domain manager about their online or offline status.

Securing open source virtualisation

As we discussed earlier, the OS HAL layer and hypervisor components work hand-in-hand to achieve virtualisation. However, it also means that the invasion of any of these components can effectively make the entire virtual layer and guest instances vulnerable to cyber attacks. It is very important to keep in mind that virtualisation is a software component, and can be affected by programmatic as well as man-made cyber attacks, just like any physical server infrastructure. Securing a virtual infrastructure is done by effectively securing each of the layers that form it. Let's first talk about typical attacks that can render a virtualisation infrastructure insecure.

Hypervisor attacks: This is a serious type of attack, whereby the attacker exploits a vulnerability of the hypervisor

layer that communicates with the HAL and guest OSs, thus infecting the entire infrastructure hosted on a physical server. There are viruses specifically designed for this purpose. The most critical moment for causing hypervisor infection is during the installation phase.

Guest OS security: From a system administrator's point of view, the VMs are pretty much the same as physical servers. Hence, all the security management techniques for physical machines apply to the VMs too. Leaving guest OSs unpatched, or not performing the correct security lockdown, can result in serious vulnerabilities.

Guest communication security: It is highly likely that guest OSs hosted on the same virtualisation infrastructure will communicate with each other. This TCP communication is usually routed through a redirector service, which is part of the hypervisor layer. Hence, there is no packet transmission on the physical network card of the physical server hosting the infrastructure. While this improves communication speeds, it introduces a limitation whereby Intrusion Detection Systems cannot detect network-layer problems. This limitation needs to be addressed correctly, else it can make serious vulnerabilities invisible to security monitoring.

Guest hopping attacks: In this type, the attacker can gain control of one of the guests (VMs), and then make use of a famous exploit called 'hypervisor escape', which can let attackers traverse from one guest system to another (called guest hopping), thus infecting the whole infrastructure. This attack is usually used to create zombie machines, which are then used to plant a distributed denial of service attack.

Management console attacks: Each virtualisation infrastructure provides a Web-based console interface for administrators to add/remove machine resources or to monitor the guest OSs. This console can introduce Web-layer attacks, which can help attackers gain control of the virtual infrastructure.

Hyperjacking: In this rare type of attack, the attacker gains control of the physical host, and creates a bogus VM. Alternatively, the attacker can get hold of an existing test virtual instance, which was deployed during the initial installation phases. Such instances are usually ignored, and hence left un-patched, thus making for vulnerable components. Attackers can make use of such machines for malicious purposes. Besides these that are specific to virtualisation servers, others, such as authentication attacks, man in the middle, packet crafting, denial of service, etc, also apply.

Virtualisation security

The following table shows the various system components of the virtualisation infrastructure, and the corresponding security layers required for end-to-end security.

Continued on page 69....